Emulação de Adversários e Detecção Atômica

1. Visão Geral

Esta etapa inicial estabelece a metodologia de **Emulação de Ameaças** para fortalecer a resiliência cibernética da organização. O foco é a replicação controlada de **TTPs (Táticas, Técnicas e Procedimentos)** utilizando o framework **Atomic Red Team**, permitindo identificar lacunas de visibilidade e validar a eficácia dos controles de segurança (**Aurora EDR** e **Sysmon**).

2. Escopo Técnico e Matriz de Testes

As atividades foram divididas em três frentes de ataque personalizadas, focando em fases críticas da *Kill Chain*:

ID	Tática Principal	Técnica (MITRE)	Ações Executadas
#4	**Execução / Descoberta**	T1056.002 / T1082	Enumeração detalhada do sistema operacional e captura de entrada de dados.
#5	**Movimentação Lateral**	T1091	Manipulação e propagação de artefatos em arquivos compartilhados (SMB).
#6	**Coleção**	T1115	Despejo de dados (*dump*), modificação de área de transferência (Clipboard) e arquivos sensíveis.

3. Arquitetura de Investigação

A mentalidade adotada é a de **Análise Forense e Resposta a Incidentes (DFIR)**:

- **Visibilidade de Endpoint:** Uso intensivo de logs do **Sysmon** para rastreamento de processos e conexões.
- **Enriquecimento de Registros:** Utilização do **Aurora EDR** para correlacionar eventos com regras Sigma de alta fidelidade.
- **Análise Experimental:** Devido à natureza "black-box" de alguns testes atômicos, a detecção baseia-se na observação direta de artefatos (arquivos criados, chaves de registro alteradas e telemetria de rede).

Insights de Especialista (Perspectiva Purple Team)

- **Abordagem Holística:** O sucesso não é apenas a execução do teste, mas a geração de logs que permitam a um analista de SOC (Tier 1-3) identificar a ameaça.
- **Foco em Artefatos:** Técnicas como a manipulação de Clipboard (T1115) são discretas; a detecção exige monitoramento de APIs específicas do Windows, o que foi validado nesta etapa.

Purple Team & Atomic Red Team

Visão Geral e Ferramental

Esta seção descreve o conjunto de ferramentas e utilitários utilizados para a emulação e investigação de ameaças no ambiente controlado do TryHackMe.

Conjunto de Ferramentas e Dicas

- **Visualizador de Eventos do Windows:** Para análise de logs brutos.
- **Editor do Registro do Windows:** Para verificação de persistência.
- **Módulo Atomic Red Team:** Framework de execução de testes.
- **THM-Utils:** Módulo PowerShell para gerenciamento e estatísticas de logs.

Tabela de Comandos: THM-Utils

Comando	Resultado
THM-LogClear-All	Limpa todos os logs do sistema.
THM-LogStats-All	Estatísticas de Application, Security, System, PowerShell e Sysmon.
THM-LogStats-Aurora	Resumo dos logs do agente Aurora.
THM-LogStats-Flag	Fornece a flag para a questão.
THM-LogStats-Sysmon	Resumo dos logs do Sysmon.

Tabela de Comandos: Atomic Red Team

Comando	Resultado
Invoke-AtomicTest All -ShowDetailsBrief	Lista todos os testes disponíveis.
Invoke-AtomicTest TXXXX-X	Executa um caso de teste específico.
Invoke-AtomicTest TXXXX-X -Cleanup	Remove artefatos e restaura arquivos modificados.

2. Tarefa 4: Executar, Investigar, Detectar

Caso: Executar, Investigar, Detectar

- **Técnicas de Referência:** * T1082: Descoberta de Informações do Sistema.
    - T1056.002: GUI Input Capture (Captura de entrada).
- **Objetivo:** Vivenciar os impactos e artefatos da descoberta do sistema, solicitações ao usuário e ações de execução de comando.

3. Evidências e Respostas (Validação)

Validação de Utilização do Módulo

Execução dos Testes (TASK-4)

Pergunta: Execute o teste **T0004-1** e abra o documento criado na Área de Trabalho. Quais são as informações da versão do sistema operacional?

Pergunta: Execute o teste **T0004-3**. Examine os registros; qual foi o comando que falhou?

- **Resposta:** <!bin/bash>

```
PS C:\Users\Administrator> Invoke-AtomicTest T0004-3 -ShowDetails
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

[********BEGIN TEST*******]
Technique: TEST T0004
Atomic Test Name: TASK-4.3 Failed command emulation
Atomic Test Number: 3
Atomic Test GUID: 76628574-0bc1-4646-8fe2-8f4427b47d15
Description: Detecting failed and suspicious commands

Attack Commands:
Executor: powershell
ElevationRequired: False
Command:
Start-Process powershell.exe -ArgumentList "-WindowStyle Hidden -Command `"<!bin/bash>`""
[!!!!!!!!END TEST!!!!!!!!]
```

Partilha Suspeita Universal (Movimentação Lateral)

Caso: Partilha Suspeita Universal

- **Técnica de Referência:** T1091 - Replicação por meio de mídia removível / Arquivos Compartilhados.
- **Enredo:** Simulação de manipulação de arquivos em unidades de rede compartilhadas. O objetivo é observar como um atacante pode alterar a integridade de documentos legítimos em servidores de arquivos para propagar códigos maliciosos ou sequestrar dados.
- **Objetivo:** Analisar a alteração de artefatos (hashes) e a rastreabilidade de comandos em volumes compartilhados.

5. Evidências e Respostas (Validação TASK-5)

Fase 5.1: Verificação de Integridade Pré-Ataque

Pergunta: Navegue pelo disco e pelas unidades e abra a pasta compartilhada. Qual é o valor SHA256 do documento ".txt"?

- **Resposta:** 3CA9FB42ACF0A347BDFDC78E0435331BC458194E4BC7FBFFB255BC4CF02CDC1A

```
PS C:\> Get-FileHash "S:\Donation_call.txt" -Algorithm SHA256

Algorithm       Hash                                                                   Path
---------       ----                                                                   ----
SHA256          3CA9FB42ACF0A347BDFDC78E0435331BC458194E4BC7FBFFB255BC4CF02CDC1A       S:\Donation_call.txt
```

Fase 5.2: Execução do Teste Atômico

Pergunta: Execute o teste **T0005-1**. Recalcule o valor SHA256 do documento. Qual é o valor de hash?

- **Resposta:** 626DBB861DCFF600DABEFCE7BF93F2C72C0F6462CC5729B963FC8242D7D43990

```
PS C:\> Invoke-AtomicTest T0005-1
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T0005-1 TASK-5   Universal Suspicious Share
C:\Windows\System32\WindowsPowerShell\v1.0\profile.ps1
WARNING: The names of some imported commands from the module 'THM-Utils' include unapproved verbs that might make them
less discoverable. To find the commands with unapproved verbs, run the Import-Module command again with the Verbose
parameter. For a list of approved verbs, type Get-Verb.
WARNING: Some imported command names contain one or more of the following restricted characters: # , ( ) {{ }} [ ] & -
/ \ $ ^ ; : " ' < > | ? @ ` * % + = ~
Atomic Hint -> Show help: help Invoke-AtomicTest
Atomic Hint -> List all tests: Invoke-AtomicTest All -ShowDetailsBrief
Atomic Hint -> Execute test: Invoke-AtomicTest TXXX-1
Atomic Hint -> Cleanup artefacts: Invoke-AtomicTest TXXX-1 -Cleanup
THM-Util Module Hint -> Cleanup Logs: THM-LogClear-All
Done executing test: T0005-1 TASK-5   Universal Suspicious Share
PS C:\> Get-FileHash "S:\Donation_call.txt" -Algorithm SHA256

Algorithm       Hash                                                                   Path
---------       ----                                                                   ----
SHA256          626DBB861DCFF600DABEFCE7BF93F2C72C0F6462CC5729B963FC8242D7D43990       S:\Donation_call.txt
```

⚙️ Insights de Especialista (Contexto Corporativo)

- **Monitoramento de Integridade (FIM):** Em um ambiente real, a alteração de um hash em uma pasta compartilhada crítica sem um ticket de mudança aprovado dispararia um alerta de **File Integrity Monitoring**.
- **Rastreabilidade SMB:** Para detectar quem alterou o arquivo, o analista deve buscar no Visualizador de Eventos por logs de auditoria de objeto (Event ID 4663) no servidor de arquivos, filtrando pelo nome do documento manipulado.

6. Tarefa 6: Despejar e Ir (Coleção e Exfiltração)

Caso: Despejar e Ir

- **Técnica de Referência:** T1115 - Dados da Área de Transferência / Histórico de Comandos.
- **Enredo:** A simulação foca na extração do histórico de linha de comando e no sequestro de arquivos do sistema. Essas técnicas são frequentemente usadas para ataques de Man-in-the-Middle (MITM), exfiltração de dados e manipulação de fluxos de trabalho de produtos de segurança.
- **Objetivo:** Compreender o impacto do despejo de dados históricos e as consequências da modificação de arquivos de sistema para fins de exfiltração.

7. Evidências e Respostas (Validação TASK-6)

Fase 6.1: Despejo de Histórico (History Dump)

Pergunta: Execute o teste **T0006-1**. Encontre o arquivo de despejo de histórico malicioso. Qual é a flag?

- **Resposta:** THM{THM_analytics_to_exfiltration_with

```
cd ..
Get-Content .\Invoke-AtomicTest-ExecutionLog.csv
cd "C:\AtomicRedTeam\atomics\T0006\restore-hst.ps1"
cd "C:\AtomicRedTeam\atomics\T0006\"
ls
 Invoke-AtomicTest T0006-1
 Invoke-AtomicTest T0006-2
 Invoke-AtomicTest T0006-1
 Invoke-AtomicTest T0006-1 -Cleanup
 Invoke-AtomicTest T0006-1
THM{THM_analytics_to_exfiltration_with_NexGenHunt}
```

Fase 6.2: Modificação de Arquivos para Exfiltração

Pergunta: Execute o teste **T0006-2**. Encontre a atividade maliciosa de modificação de arquivos do sistema. Qual é a flag?

- **Resposta:** THM{NextGenHunt.thm.jhn}

```
#       102.54.94.97     rhino.acme.com          # source server
#        38.25.63.10     x.acme.com              # x client host

# localhost name resolution is handled within DNS itself.
#        127.0.0.1       localhost
#        ::1             localhost
THM.10.10.JHN    THM{NextGenHunt.thm.jhn}        # NextGenHunt analytics
THM.10.10.JHN    THM{NextGenHunt.thm.jhn}        # NextGenHunt analytics
THM.10.10.JHN    THM{NextGenHunt.thm.jhn}        # NextGenHunt analytics
```

Insights de Especialista (Contexto SOC/DFIR)

- **Monitoramento de Console:** Atacantes buscam o histórico de comandos (como o arquivo `ConsoleHost_history.txt` do PowerShell) para encontrar senhas digitadas por erro ou endereços de servidores internos. No SOC, monitorar o acesso a esses arquivos por processos incomuns é um método de detecção eficaz.
- **Integridade de Arquivos de Sistema:** A modificação de arquivos de sistema (como o arquivo `hosts`) pode ser usada para redirecionar o tráfego legítimo para servidores controlados pelo atacante. Ferramentas de **EDR** devem ser configuradas para alertar qualquer escrita em diretórios como `C:\Windows\System32\drivers\etc\`.

Entre - Descubra e Oculte (Credenciais e Contas Locais)

Caso: Descubra e Oculte

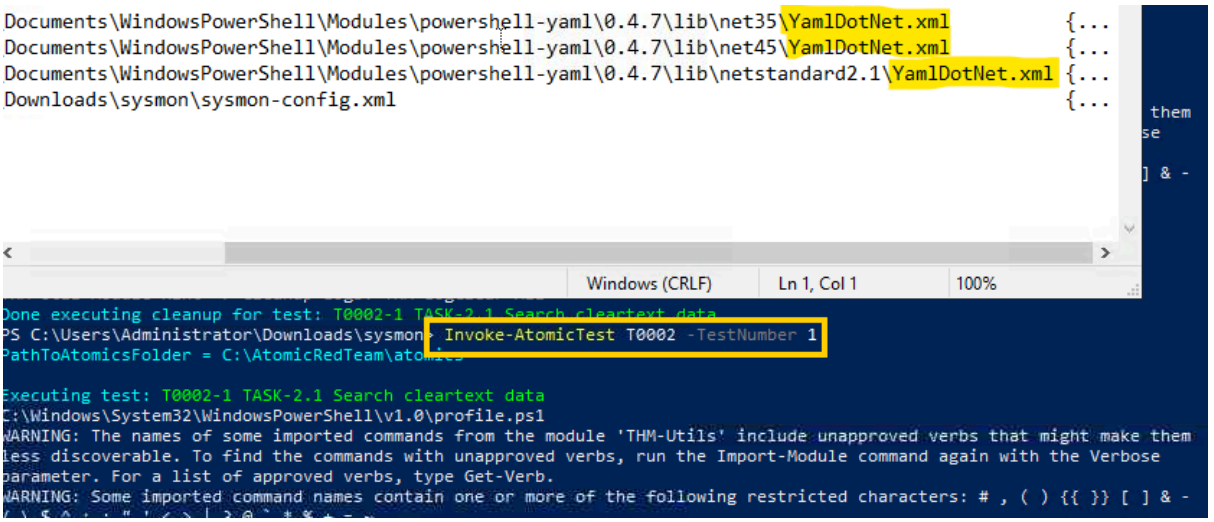
- **Técnicas de Referência:** * **T1552.001:** Credenciais Não Seguras - Credenciais em Arquivos.
    - **T1078.003:** Contas Válidas - Contas Locais.
- **Enredo:** Simulação de um adversário que já obteve acesso inicial e agora busca escalar privilégios ou manter persistência através da busca por senhas esquecidas em arquivos e da criação de contas "isca" (decoy) com nomes similares a contas legítimas.
- **Objetivo:** Experimentar o impacto de deixar dados sensíveis desprotegidos e entender como contas clonadas podem ser usadas para mascarar atividades maliciosas.

Evidências e Respostas (Validação TASK-2)

Fase 2.1: Busca por Dados em Texto Claro (Cleartext)

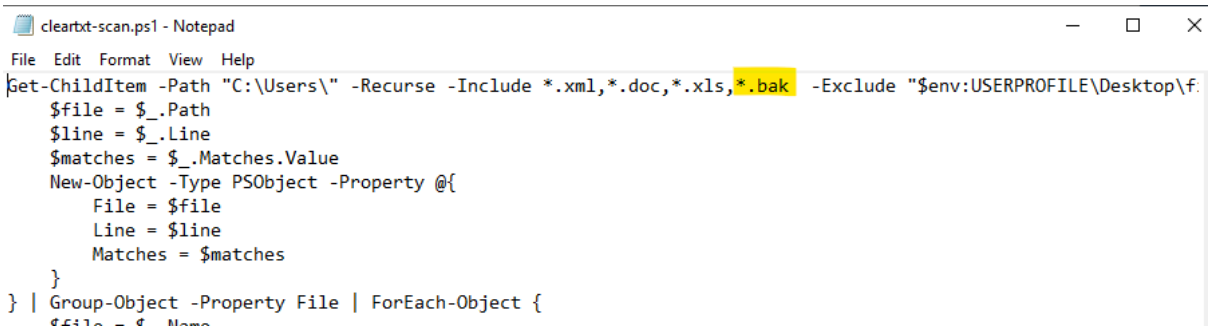
Pergunta: Execute o teste **T0002-1** e abra o documento criado na Área de Trabalho. Qual arquivo de biblioteca do PowerShell é detectado?

- **Resposta:** YamlDotNet.xml



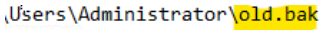
Pergunta: Agora, acesse o caminho do arquivo atomics e atualize o script executado para incluir todos os arquivos "bak". Qual trecho de código precisa ser adicionado ao código?

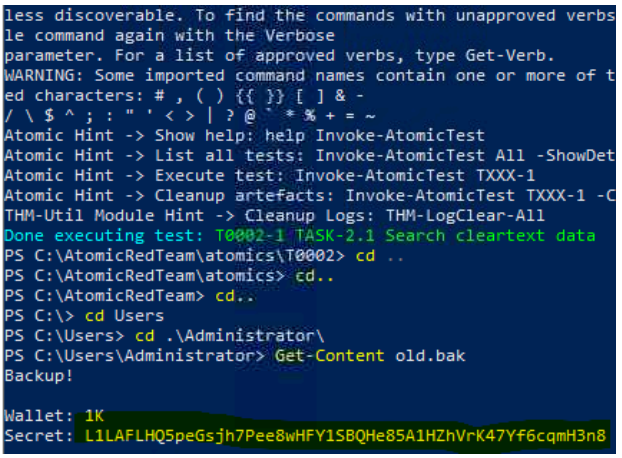
- **Resposta:**: ,*.bak



Pergunta: Execute o comando de limpeza para o teste **T0002-1** e execute o teste novamente. Abra o arquivo de saída e investigue os arquivos detectados. Qual é a chave secreta?

- **Resposta:** L1LAFLHQ5peGsjh7Pee8wHFY1SBQHe85A1HZhVrK47Yf6cqmH3n8





Fase 2.2: Criação de Conta Clone/Isca (Decoy Account)

Pergunta: Execute o teste **T0002-2** e investigue os registros. Qual é o novo nome da conta?

- **Resposta:** Adminstrator

```
PS C:\Users\Administrator> Invoke-AtomicTest T0002 -TestNumber 2
PathToAtomicsFolder = C:\AtomicRedTeam\atomics

Executing test: T0002-2 TASK-2.2 Create clone/decoy account
C:\Windows\System32\WindowsPowerShell\v1.0\profile.ps1
WARNING: The names of some imported commands from the module 'THM-Utils' include
less discoverable. To find the commands with unapproved verbs, run the Import-Mod
parameter. For a list of approved verbs, type Get-Verb.
WARNING: Some imported command names contain one or more of the following restric
/ \ $ ^ ; : " ' < > | ? @ ` * % + = ~
Atomic Hint -> Show help: help Invoke-AtomicTest
Atomic Hint -> List all tests: Invoke-AtomicTest All -ShowDetailsBrief
Atomic Hint -> Execute test: Invoke-AtomicTest TXXX-1
Atomic Hint -> Cleanup artefacts: Invoke-AtomicTest TXXX-1 -Cleanup
THM-Util Module Hint -> Cleanup Logs: THM-LogClear-All
New-LocalUser : User Adminstrator  already exists.
At line:2 char:1
+ New-LocalUser -Name 'Adminstrator ' -Password $Password -Description  ...
```

Insights de Especialista (Contexto de Auditoria e SOC)

- **Prevenção de Credenciais:** O uso de ferramentas de **Secret Management** (como HashiCorp Vault ou Azure Key Vault) é a única forma eficaz de mitigar a técnica T1552. Auditorias automáticas em scripts de administradores são essenciais para evitar o armazenamento de senhas em comentários.
- **Identificação de Typosquatting Local:** Atacantes criam contas como `Administrador` (com 'o' no lugar de zero) ou `Sytem`. No SOC, monitoramos o **Event ID 4720 (A user account was created)** e comparamos o nome criado com uma "whitelist" de nomes de contas padrão da empresa para detectar anomalias imediatamente.

Relatório de Laboratório — Atomic Red Team (T0003)

Objetivo

Vivenciar os impactos e artefatos gerados por:

- Criação de serviços
- Modificações no registro
- Alterações em arquivos
- Persistência maliciosa

Cenário

A equipe realizou simulações de:

- Persistência via serviços
- Defacement (alteração visual/comportamental)
- Simulação de ransomware
- Inserção de comando malicioso no registro